

Exercício 1 — Severidade no CVE

Como a severidade dos CVEs afeta a priorização das medidas de segurança de uma organização?

Forneça exemplos de como diferentes níveis de severidade (baixo, médio, alto, crítico) influenciam as estratégias de resposta.

Entendendo a Severidade no CVE e seu Impacto na Priorização de Segurança

Como a Severidade Afeta a Priorização de Segurança

Toda organização opera com recursos limitados — seja tempo de equipe, janelas de manutenção ou orçamento. Como centenas de novos CVEs são publicados todo mês, é impossível tratá-los todos simultaneamente.

É aqui que as classificações de severidade se tornam essenciais. Calculadas usando o Sistema de Pontuação de Vulnerabilidades Comum (CVSS) e publicadas pelo Banco de Dados Nacional de Vulnerabilidades (NVD), a severidade funciona como um mecanismo de triagem que ajuda as organizações a determinar quais vulnerabilidades representam o maior risco e devem ser tratadas primeiro.

Sem essa priorização, as equipes de segurança podem corrigir vulnerabilidades na ordem em que são descobertas — ou pior, atrasar a remediação por falta de critérios claros. Isso pode deixar vulnerabilidades críticas sem correção por meses, aumentando significativamente o risco de comprometimento.

Níveis de Severidade e Estratégias de Resposta

Crítico (CVSS: 9.0-10.0)

Exemplo: CVE-2021-44228 (Log4Shell) — CVSS: 10.0

Estratégia de Resposta: Vulnerabilidades críticas exigem remediação imediata, frequentemente fora do ciclo normal de patches. Podem justificar reuniões emergenciais, comunicação em nível executivo e, em alguns casos, a desativação temporária dos serviços afetados até que uma correção esteja disponível.

SLA típico: 24–72 horas.

Alto (CVSS: 7.0–8.9)

Exemplo: CVE-2021-34527 (PrintNightmare) — CVSS: 8.8

Estratégia de Resposta: Vulnerabilidades de alta severidade devem ser priorizadas e normalmente tratadas durante o próximo ciclo de patches agendado, geralmente dentro de uma a duas semanas. A remediação pode ser acelerada se exploração ativa ou exploits públicos forem detectados.

Médio (CVSS: 4.0–6.9)

Exemplo: Uma vulnerabilidade que requer autenticação local e interação do usuário para ser explorada.

Estratégia de Resposta: Vulnerabilidades de severidade média são geralmente tratadas durante os ciclos regulares de manutenção mensal ou trimestral. As organizações devem monitorar o cenário de ameaças caso exploits públicos surjam e aumentem o risco prático.

Baixo (CVSS: 0.1–3.9)

Exemplo: Uma vulnerabilidade que requer acesso físico ao dispositivo e privilégios administrativos preexistentes.

Estratégia de Resposta: Vulnerabilidades de baixa severidade são tipicamente documentadas no backlog de melhorias e corrigidas conforme os recursos permitirem. Geralmente não requerem ação urgente.

Fatores que Influenciam a Priorização Além do CVSS

Disponibilidade de Exploit Público

A existência de um exploit publicamente disponível pode aumentar significativamente a urgência, mesmo para vulnerabilidades com pontuação média.

Criticidade do Negócio

Se o sistema afetado suporta operações críticas do negócio, a vulnerabilidade pode receber prioridade mais alta por meio das Métricas Ambientais do CVSS ou avaliações internas de risco.

Exposição à Internet vs. Acesso Interno

Uma vulnerabilidade que afeta um sistema voltado para a internet geralmente apresenta um risco prático maior do que a mesma vulnerabilidade em uma rede interna isolada.

Disponibilidade de Patch

Quando nenhum patch está disponível, implementar mitigações temporárias torna-se prioridade máxima para reduzir a exposição até que uma correção permanente seja lançada.

Considerações Finais

As pontuações CVSS fornecem um ponto de partida eficaz para o gerenciamento de vulnerabilidades, mas não devem ser o único fator que orienta as decisões de remediação. As organizações também devem considerar disponibilidade de exploits, criticidade de ativos, nível de exposição e impacto operacional.

Ao combinar classificações de severidade com contexto do mundo real, as equipes de segurança podem tomar decisões informadas, alocar recursos de forma eficaz e reduzir o risco organizacional com mais eficiência.